SQL Server DBA Policy Template Set

13 October 2026

Purpose and how to use this set

This set gives a SQL Server DBA function 20 ready-to-adapt policies for commercial and regulated non-NHS environments (defence, policing, finance, SaaS). Each policy has the same skeleton, so you can lift it into your own document control format.

Standard skeleton for every policy: Purpose / Scope / Policy statements / Roles and responsibilities / Exceptions / Evidence and metrics / Review cycle (annual, or after a major incident).

Values shown are of two kinds. **Facts** come from a named external source (for example the Cyber Essentials 14-day patching rule or the UK GDPR 72-hour breach limit) and are listed in the Basis of values table. **Recommended defaults** are common practice that you should confirm with each system owner. Organisation-specific data, such as your server inventory and owners, is not known to this document and is left in the register template.

Tiering framework

Classify every database by business impact, then apply the matching defaults below. All policies in this set refer back to these tiers.

Tier	Typical systems	RPO	RTO	HA	Backups	DR test
1 - Critical	Case, dispatch, financial, safety-related	<= 5 min	<= 1 hr	Always On AG, synchronous in-site	Full weekly, diff daily, log every 5 min	Twice a year
2 - Important	Line-of-business, reporting feeds	<= 1 hr	<= 4 hrs	AG asynchronous or FCI	Full weekly, diff daily, log every 15-30 min	Annually
3 - Standard	Internal tools, dev/test, archives	<= 24 hrs	<= 24 hrs	None required	Full weekly, diff daily	Restore test only

Values are starting defaults: set them with the business owner of each system and record the tier in the inventory.

Availability and recovery policies

1. Backup and restore policy

- All production databases are backed up to the schedule for their tier, with CHECKSUM and compression enabled.
- Backups are encrypted, copied to a separate location or account within 15 minutes of completion, and retained for 35 days online and 12 months in long-term storage.
- At least one copy is immutable or logically air-gapped against ransomware.
- Restore tests: Tier 1 monthly, Tier 2 quarterly, Tier 3 annually. Results, duration and any failure are recorded.
- Evidence: backup success report, restore test log, msdb history exceptions.

2. Disaster recovery and RPO/RTO policy

- Every system has an owner-approved tier with RPO and RTO recorded in the inventory.
- A DR plan exists per Tier 1 and 2 system: failover steps, decision authority, communications, fail-back.
- DR tests follow the tier schedule; findings are logged and closed within 30 days.
- Evidence: signed DR test reports, measured RTO/RPO against target.

3. High availability standards

- Tier 1: Always On Availability Groups with automatic failover in-site and a secondary at a second location. Tier 2: AG, FCI or log shipping. Tier 3: none required.
- Quorum, listener, and failover settings follow the build baseline; failover is tested at least twice a year for Tier 1.
- HA is never treated as a substitute for backups.

Security and access policies

4. Access control and least privilege

- Access is role-based using AD groups mapped to database roles; direct user grants are exceptions.
- Privileged access (sysadmin, db_owner, securityadmin) is limited to named DBAs, approved by the data owner, and time-bound where tooling allows.
- Separation of duties: developers have no standing production write access; DBAs do not approve their own access.
- Access reviews run quarterly for Tier 1 and 2 and annually for Tier 3. Leavers are removed within 1 working day.

5. Authentication standards

- Windows/AD authentication is the default; SQL authentication needs a documented reason.
- The sa login is disabled or renamed; no shared DBA accounts.
- Service accounts are gMSA where possible, least-privileged, with credentials in a vault and rotated at least annually.
- Privileged accounts require MFA at the jump host or PAM layer.

6. Encryption policy

- TLS 1.2 or higher is enforced for all connections; legacy protocols are disabled.
- TDE is on for databases holding personal, financial or OFFICIAL-SENSITIVE data; backups are encrypted regardless of tier.
- Always Encrypted or column-level encryption for the most sensitive fields where the app supports it.
- Keys and certificates are backed up separately from the data, with named custodians and expiry tracking.

7. Auditing and logging

- SQL Server Audit captures logins, failed logins, permission changes, schema changes and privileged activity on Tier 1 and 2 systems.
- Audit data is shipped off the server to a central SIEM or write-once store, is tamper-resistant, and is kept for 12 months minimum.
- Alerts are raised for changes to sysadmin membership and repeated login failures.

8. Data classification and protection

- Every database is classified (for example Public, Internal, Confidential, Restricted) by its data owner, and the label drives controls.
- Personal data is handled under UK GDPR and the Data Protection Act 2018: minimum necessary, purpose-bound, and recorded in the register of processing.
- Non-production copies of Confidential or Restricted data are masked or synthetic; restoring live data to dev/test needs approval.
- Where government or defence data is held, apply the applicable security classification and handling rules.

Change and release policies

9. Change management

- Production changes need a ticket with description, risk, test evidence, rollback plan and approver; no change without one.
- Changes are classed as standard (pre-approved), normal, or emergency; emergency changes are reviewed within 2 working days.
- Tier 1 changes run in agreed maintenance windows and are communicated to affected users in advance.
- Each change is verified after deployment and closed with the outcome recorded.

10. Patching policy

- Security updates are applied within 14 days of release where the vendor rates them critical or high risk, or the CVSS v3 score is 7 or above (a Cyber Essentials requirement) and cumulative updates are applied at least every 6 months.
- Patches are tested in non-production first; Tier 1 AG nodes are patched secondary first, then failed over.
- No instance runs on an unsupported SQL Server or OS version (see the lifecycle table) without a risk-accepted exception and a retirement date.
- A patch and end-of-support register is reviewed monthly.

11. Deployment standards

- All schema and code changes are source-controlled scripts, peer-reviewed, and deployed through a pipeline or controlled runbook.
- No ad hoc changes in production; break-glass fixes are logged and back-ported to source control.
- Scripts are idempotent where practical, and include rollback.
- Deployment accounts are separate from named personal accounts.

Operations and performance policies

12. Monitoring and alerting

- All production instances are monitored for availability, failed jobs, backup age, AG health and lag, disk space, blocking, deadlocks and long-running queries.
- Alert thresholds are set per tier, routed to an on-call rota, and escalate if unacknowledged within 15 minutes (Tier 1).
- Alerts that fire repeatedly without action are tuned or removed each quarter.

13. Maintenance standards

- DBCC CHECKDB runs at least weekly on Tier 1 and 2, and corruption triggers the incident process immediately.
- Index and statistics maintenance is threshold-based, not blind rebuilds, and runs outside peak hours.
- File layout, tempdb (multiple equally sized files), autogrowth and instant file initialisation follow the build baseline.
- Maintenance jobs are owned, documented and monitored for failure.

14. Capacity planning

- Data, log, tempdb, CPU, memory and I/O trends are captured at least monthly.
- Forecasts cover 12 months and are reviewed quarterly with infrastructure and system owners.
- Any volume above 80% used or a forecast breach within 90 days raises a ticket.

15. Performance baselining and incident response

- A baseline (waits, I/O latency, CPU, top queries via Query Store) is captured per Tier 1 and 2 system and refreshed after major change.
- Blocking, deadlock and slow-query incidents are triaged by severity, with first response targets per tier.
- Root cause, fix and prevention are recorded; Severity 1 and 2 incidents get a post-incident review within 5 working days.
- Query Store is enabled on supported versions with sensible retention.

Governance policies

16. Configuration standards

- A build baseline defines max server memory, MAXDOP, cost threshold for parallelism, compatibility level, collation, trace flags, naming conventions and disabled features (xp_cmdshell, unused surface area).
- Deviations are documented and approved; drift is checked at least quarterly.

17. Data retention and disposal

- Retention periods follow the records schedule and legal obligations, set per data set by its owner.
- Data past retention is archived or securely deleted, and deletion is evidenced.
- Decommissioned servers and media are wiped to a recognised standard, with a certificate of destruction where required.

18. Documentation and runbooks

- A live inventory records every instance and database: version, owner, tier, classification, HA/DR design and support contacts.
- Runbooks exist for failover, restore, patching, access requests and common incidents, and are reviewed at least annually and after use.

19. Incident and breach management

- Security and data incidents are reported to the Information Security team and the Data Protection Officer immediately on discovery.
- A personal data breach is assessed for ICO notification within 72 hours of becoming aware (UK GDPR); the DBA team supplies logs and scope.
- Post-incident reviews record cause, impact, actions and owners.

20. Third-party, vendor and cloud policy

- Supplier and vendor access is named, time-limited, logged and revoked on completion.
- Cloud database services (Azure SQL, Managed Instance, AWS RDS, or IaaS) follow the same tier, backup, encryption and audit standards, with the shared-responsibility split documented.
- Data residency is the UK unless approved, and exit and data return terms are agreed in the contract.

Reference data: SQL Server support lifecycle

Status is shown as at 13 October 2026. Dates are Microsoft lifecycle dates as reported by the sources listed at the end; confirm against the Microsoft Lifecycle page before acting.

Version	Released	End of mainstream support	End of extended support	Status
SQL Server 2016	1 Jun 2016	13 Jul 2021	14 Jul 2026	Past end of extended support. Retire, upgrade or confirm any paid extended security update.
SQL Server 2017	29 Sep 2017	11 Oct 2022	12 Oct 2027	Extended support, security fixes only. About 12 months left: plan the upgrade now.
SQL Server 2019	4 Nov 2019	28 Feb 2025	8 Jan 2030	Extended support, security fixes only.
SQL Server 2022	16 Nov 2022	11 Jan 2028	11 Jan 2033	Mainstream support.
SQL Server 2025	18 Nov 2025	6 Jan 2031	6 Jan 2036	Mainstream support.

Basis of values

Value in this set	Type	Basis
Critical/high security updates applied within 14 days of release	Fact	Cyber Essentials security update management: vendor-rated critical or high risk, or CVSS v3 score 7+ (IASME).
In-scope software must be supported	Fact	Cyber Essentials: unsupported software is a failing point, hence the exception rule for end-of-support SQL Server.
Personal data breach assessed for ICO notification within 72 hours	Fact	UK GDPR Article 33.
Cyber Essentials five controls: firewalls, secure configuration, user access control, malware protection, security update management	Fact	Cyber Essentials scheme.
SQL Server end-of-support dates	Fact	Microsoft lifecycle dates (see Sources).
Tier RPO/RTO, backup frequency, retention (35 days / 12 months), restore and DR test cadence	Recommended default	Common practice. Set per system with the data owner; not a legal or vendor requirement.
Access review cadence, leaver removal in 1 working day, 15-minute escalation, 80% capacity threshold, 5-day post-incident review	Recommended default	Common practice. Adjust to your risk appetite.

Database inventory register (to complete)

Your own systems cannot be populated from outside the organisation. Complete this register first; every tier-based control depends on it.

Instance / database	SQL version	Data owner	Tier	Classification	HA / DR	Last restore test

Framework mapping and adoption checklist

The table maps the policies to ISO/IEC 27001:2022 Annex A, Cyber Essentials and UK GDPR. It is a guide for gap analysis, not a compliance claim; confirm against your own scope and auditor.

Policies	ISO 27001:2022 Annex A	Cyber Essentials	UK GDPR
1-3 Backup, DR, HA	A.8.13, A.8.14, A.5.30	-	Art. 32 (availability, resilience)
4-5 Access, authentication	A.5.15, A.8.2, A.8.5	User access control	Art. 32
6 Encryption	A.8.24	Secure configuration	Art. 32
7 Auditing	A.8.15, A.8.16	-	Art. 5(2) accountability
8 Classification	A.5.12, A.5.13	-	Arts. 5, 30
9, 11 Change, deployment	A.8.32	-	-
10 Patching	A.8.8	Security update management	-
12-15 Operations	A.8.6, A.8.16, A.8.9	Secure configuration	-
16 Configuration	A.8.9	Secure configuration	-
17 Retention, disposal	A.8.10	-	Art. 5(1)(e) storage limitation
19 Incident, breach	A.5.24-A.5.28	-	Arts. 33, 34
20 Vendor and cloud	A.5.19-A.5.23	-	Art. 28 processors

Adoption checklist

- [ ] Tier every database and record owners in the inventory
- [ ] Confirm the default values with business owners
- [ ] Adapt the skeleton to your document control format
- [ ] Approve at the right governance forum and assign a policy owner
- [ ] Capture evidence for each policy (reports, logs, test results)
- [ ] Schedule the annual review and the first access review

Sources

- IASME Cyber Essentials requirements, security update management (iasme.atlassian.net/wiki/x/SADmv)
- endoflife.ai, SQL Server end of life (endoflife.ai/article-sql-server-eol)
- Coeo, SQL Server 2016 end of support, 21 May 2026 (coeo.com/?p=37071)
- MSSQLTips, SQL Server release dates and lifecycle (mssqltips.com/tutorial/sql-server-release-dates-and-lifecycle)
- UK GDPR Article 33, personal data breach notification (ICO)